

Manual 49 — NIST AI RMF 1.0 + NIST AI 600-1: Perfil de Riesgo de IA Generativa

****Estado:**** FUENTE CONTROLADA DE LOCALIZACIÓN

****Idioma:**** Español Latinoamericano (`es-419`)

****Base normativa/metodológica:**** NIST AI RMF 1.0 y NIST AI 600-1

****Fecha de verificación de fuente:**** 1 de septiembre de 2026

Objetivo

Enseñar a profesionales a convertir NIST AI RMF 1.0 y el perfil de IA generativa NIST AI 600-1 en un sistema operativo de gobernanza, gestión de riesgos, pruebas, evidencia y mejora continua para IA empresarial, incluida IA generativa, RAG, modelos de terceros y sistemas agentivos.

NIST AI RMF y NIST AI 600-1 son marcos voluntarios. Este manual no representa alineación con NIST como certificación, cumplimiento legal ni sustituto de obligaciones regulatorias aplicables.

Arquitectura operativa

El manual organiza la práctica alrededor de las cuatro funciones del AI RMF:

1. ****GOVERN — Gobernar:**** establecer políticas, roles, rendición de cuentas, apetito de riesgo, inventario, competencias, supervisión, terceros y gobernanza de cambios.
2. ****MAP — Mapear:**** definir contexto, finalidad, usuarios, personas afectadas, dependencias, riesgos previsibles, impactos y condiciones de uso.
3. ****MEASURE — Medir:**** diseñar TEVV, criterios, métricas, pruebas, evidencia, evaluación de seguridad, privacidad, robustez, sesgo/fairness cuando corresponda y evaluación de riesgos GenAI.
4. ****MANAGE — Gestionar:**** priorizar, tratar, aceptar, transferir, mitigar o retirar riesgos; operar monitoreo, incidentes, cambios y reevaluación.

Extensión GenAI

Para IA generativa, aplicar además controles específicos sobre:

- confabulación y calidad de salida;
- contenido dañino, inseguro o engañoso;
- privacidad, memorización y divulgación de datos;
- propiedad intelectual y procedencia de contenido;
- seguridad de modelos, prompts, herramientas y cadenas RAG;
- envenenamiento y manipulación de fuentes;
- abuso, uso dual y automatización excesiva;
- dependencia de proveedores y modelos fundacionales;
- evaluación de comportamiento emergente;
- monitoreo de deriva y cambios de versión;
- agentes, delegación, identidades, permisos y consecuencias de acciones.

Cadena de control y evidencia

****Contexto → riesgo → objetivo de control → actividad → responsable → frecuencia/gatillo → evidencia → método de prueba → resultado → excepción → remediación → decisión de riesgo residual****

La evidencia debe ser reproducible y vinculada a la versión exacta del sistema, modelo, proveedor, configuración, datos, prompt/orquestación y entorno evaluado.

RAG y gobernanza de fuentes

Para sistemas con recuperación aumentada:

- registrar fuentes y propietarios;
- controlar autorización y sensibilidad;
- evaluar calidad, actualidad y procedencia;
- probar inyección indirecta y contaminación de contexto;
- limitar recuperación por identidad, finalidad y necesidad;
- registrar citas/procedencia cuando corresponda;
- monitorear cambios en índices, embeddings, fuentes y permisos.

Proveedores y modelos de terceros

La adopción de un modelo externo no transfiere la responsabilidad del sistema completo. Mantener due diligence, documentación de versión, condiciones de uso, controles contractuales, seguridad, privacidad, cambios, incidentes, evidencia de evaluación y estrategia de sustitución/salida.

TEVV y assurance

Las pruebas deben estar vinculadas a riesgos y criterios de aceptación. Incluir, según materialidad:

- pruebas funcionales y de desempeño;
- robustez y sensibilidad;
- seguridad y adversarial testing;
- privacidad y fuga de datos;
- fairness/sesgo cuando sea relevante;
- evaluación de RAG;
- evaluación de agentes y acciones;
- pruebas de supervisión humana;
- escenarios de uso indebido previsible;
- análisis de límites y casos extremos.

Un resultado de prueba no demuestra por sí solo que el sistema sea seguro o conforme. Los hallazgos deben gobernarse mediante severidad, propietario, remediación, compensaciones y decisión explícita de riesgo residual.

Escenarios de entrenamiento

5. asistente interno basado en modelo fundacional externo;
6. chatbot de atención al cliente con RAG;
7. generación de contenido para decisiones reguladas;

8. copiloto de ingeniería con acceso a código y secretos;
9. agente con herramientas de correo, archivos y APIs;
10. cambio de modelo/proveedor después de producción;
11. incidente por fuga de datos o prompt injection;
12. degradación de desempeño y deriva después de actualización.

Para cada escenario documentar: contexto, inventario, actores, riesgos, GOVERN/MAP/MEASURE/MANAGE, controles, evidencia, pruebas, decisión de riesgo residual, monitoreo y gatillos de revalidación.

Criterio de finalización

La persona que complete el Manual 49 debe poder tomar un sistema de IA desde el inventario y contexto hasta el mapeo de riesgos, diseño de controles, TEVV, aceptación, operación, monitoreo, incidentes, cambios y mejora continua, conservando la distinción entre un marco voluntario NIST y obligaciones legales o contractuales externas.

Límite de publicación

Antes de congelar el candidato, se debe volver a verificar el estado oficial de NIST AI RMF y NIST AI 600-1. Si NIST publica una revisión material del AI RMF o del perfil GenAI, se requiere reconciliación de alcance antes de generar o aprobar un candidato final.